SBOM / CVE / Patch

Çıktı: Vulnerability Decision

Ad Soyad Ahmed Mıhemid | Grup 4/B gündüz | Tarih 26.10.2026

Kavram: SBOM = yazılım malzeme listesi · **CVE** = açığın kayıt no'su · **CVSS** = ciddiyet (0–10). Bir CVE sizi etkiler mi? Üç şart: bileşen **var**, sürüm **etkileniyor**, açık **ulaşılabilir**.

Verilen zafiyet kaydı

Bileşen	Component X (PLC firmware kütüphanesi)
Sürüm	2.4
CVE	CVE-XXXX-XXXX
Önem	Critical (CVSS 9.8)
Yama	Mevcut

Görev — karar akışı

1. Bu CVE sizi gerçekten etkiliyor mu? (üç şartı kontrol edin)

   Sistemin etkilenip etkilenmediğini anlamak için şu üç şartın sağlanması gerekir:
   1- Sisteminizde "Component X (PLC firmware kütüphanesi)" bileşeni bulunuyor mu? 2- Kullandığınız bu bileşenin sürümü 2.4 mü?
   3- Bu zafiyet (açık) sisteminize dışarıdan veya içeriden erişilebilir durumda mı?

2. Üretimi hemen durdurur musunuz? Neden / neden değil?

   Hayır, üretim hemen durdurulmaz. Endüstriyel ortamlarda üretimi durdurmak büyük maliyetlere ve operasyonel sorunlara yol açar. Sadece insan hayatını veya tesisin bütünlüğünü doğrudan tehdit eden aktif bir saldırı varsa durdurma kararı alınır.

3. Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?

   Yama kesinlikle doğrudan üretim hattına uygulanmaz. İlk olarak, üretim ortamını taklit eden, izole edilmiş bir test ortamında (test environment) uygulanarak sistemin işleyişini bozup bozmadığı kontrol edilmelidir.

4. Bu yama bir safety validation etkiliyor mu? Nasıl anlarsınız?

   Evet, etkileyebilir. Bunu anlamak için üreticinin yayınladığı yama notlarını (release notes) incelemek ve Değişim Etki Analizi (Change Impact Analysis) yaparak PLC'nin güvenlik işlevlerinde bir değişiklik olup olmadığını kontrol etmek gerekir.

5. Yama mümkün değilse compensating control (telafi edici önlem) ne olur?

   Eğer yama uygulanamıyorsa alınabilecek telafi edici önlemler şunlardır:
   - Ağ segmentasyonu ile etkilenen PLC'yi diğer ağlardan izole etmek.
   - Endüstriyel güvenlik duvarı kullanarak erişimi kısıtlamak.
   - Ağ üzerindeki olağan dışı hareketleri tespit etmek için izleme (monitoring) seviyesini artırmak.

Bu föyün çıktısı **Vulnerability Decision** → Evidence Pack **EP 09 · 10 · 11** başlığına oturur.